FIT2093 Assignment 3

Task 1: Committee Member Security Test

Task 1A

Based on the application behaviour for the login and welcome pages of Alice Fans Club, there are a few potential XSS vulnerability points.

First, in both the login and welcome pages, there are user input fields that can be filled in by the user. These fields include the username, password, city, year and month. If these fields are not properly sanitized, an attacker could inject malicious scripts into these fields and the scripts will be executed in the user's session.

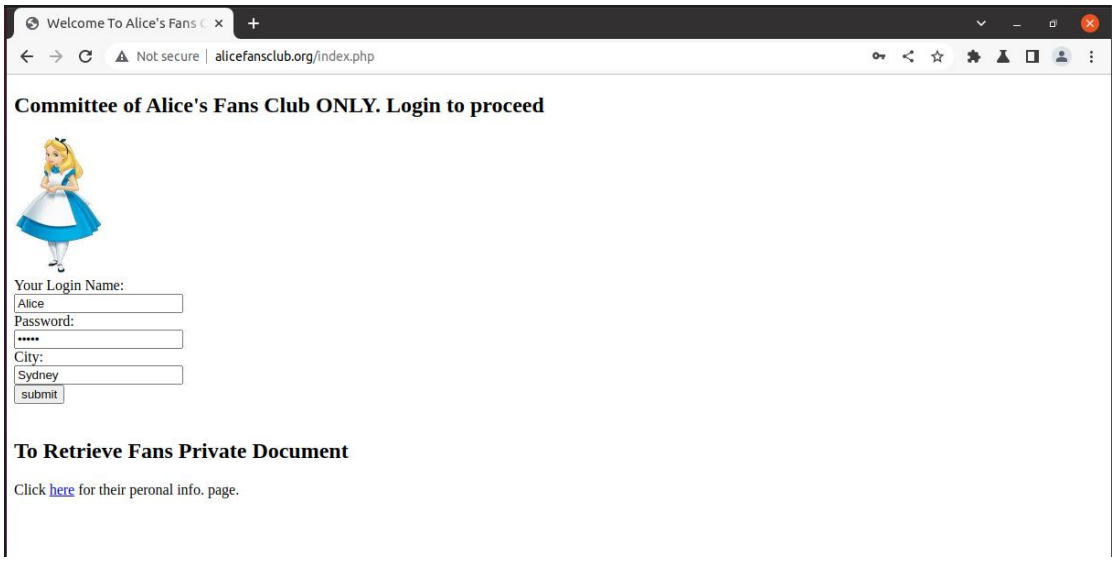
Furthermore, an attacker could intercept the user's session and see what they typed in the input boxes. If the input is not properly encoded, an attacker could potentially get access to the user's sensitive information such as their password and city.

To summarize, if the user input fields do not have sufficient restraints, an attacker could inject malicious scripts or obtain private information from the user.

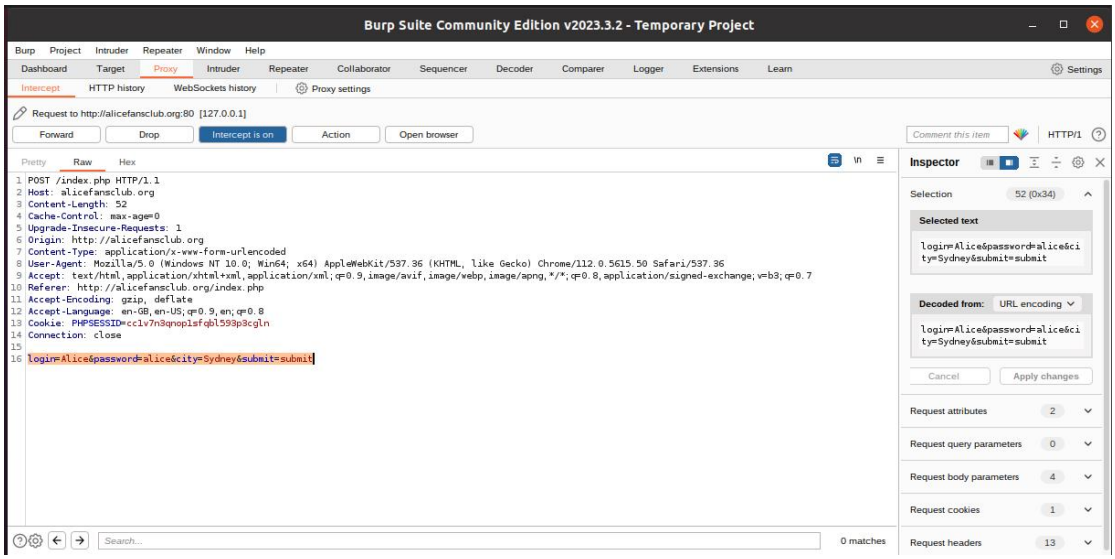
Task 1B

Vulnerability 1: Attacker can obtain user's sensitive information.

First, the user fills in their login details.

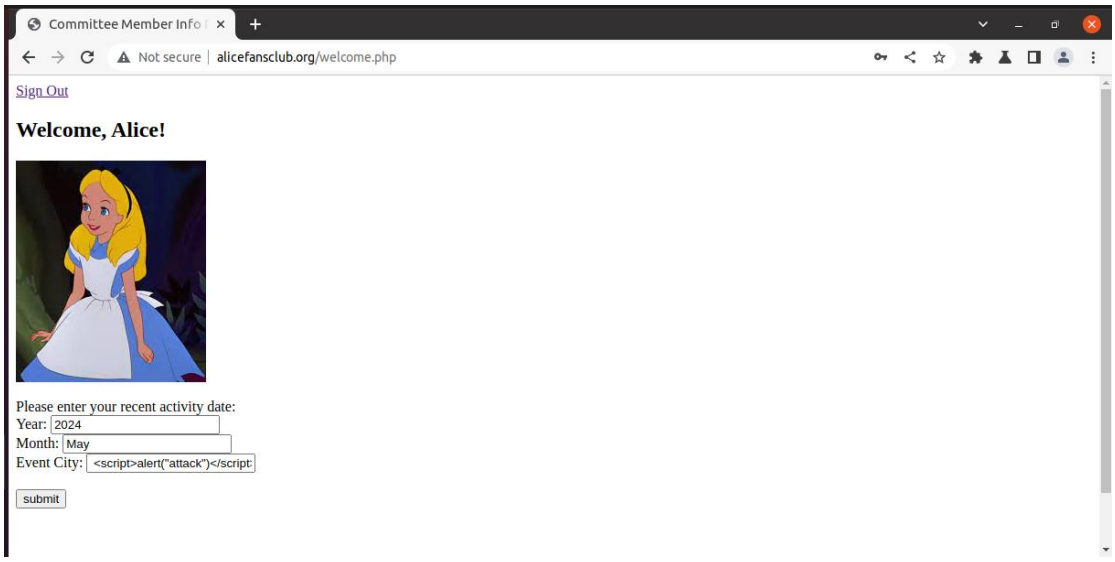


The attacker can intercept the user's session and obtain their password and city, which is sensitive information belonging to the user and not meant to be obtained by others.

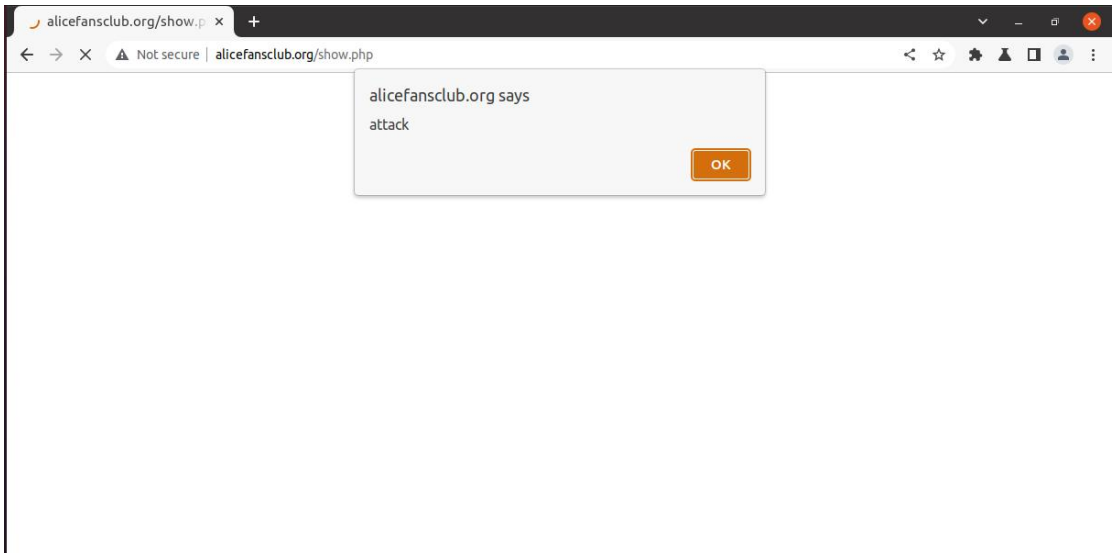


Vulnerability 2: Attacker injects malicious script into user's session.

Once the user logs in, they can fill in the activity details. As seen below, the input box does not prevent scripts from running.

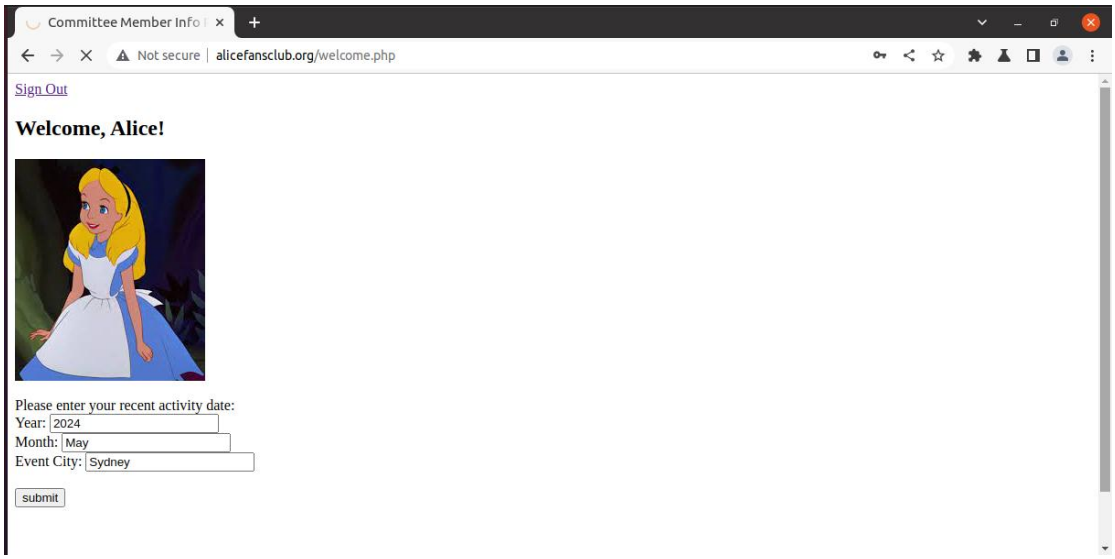


Outcome of running the script through the input box:

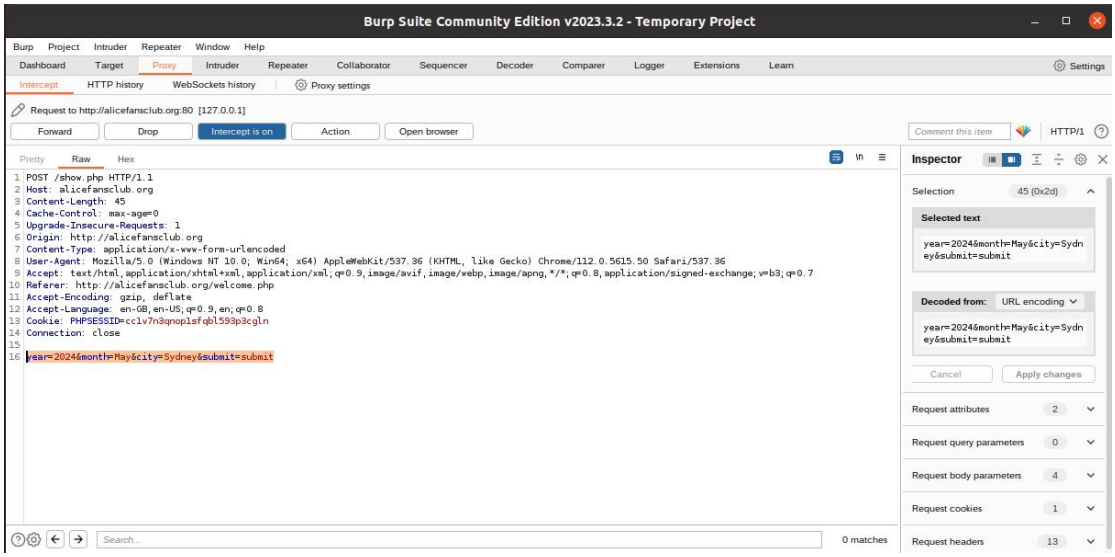


If the user's session was intercepted, an attacker could replace the user's input with their malicious script.

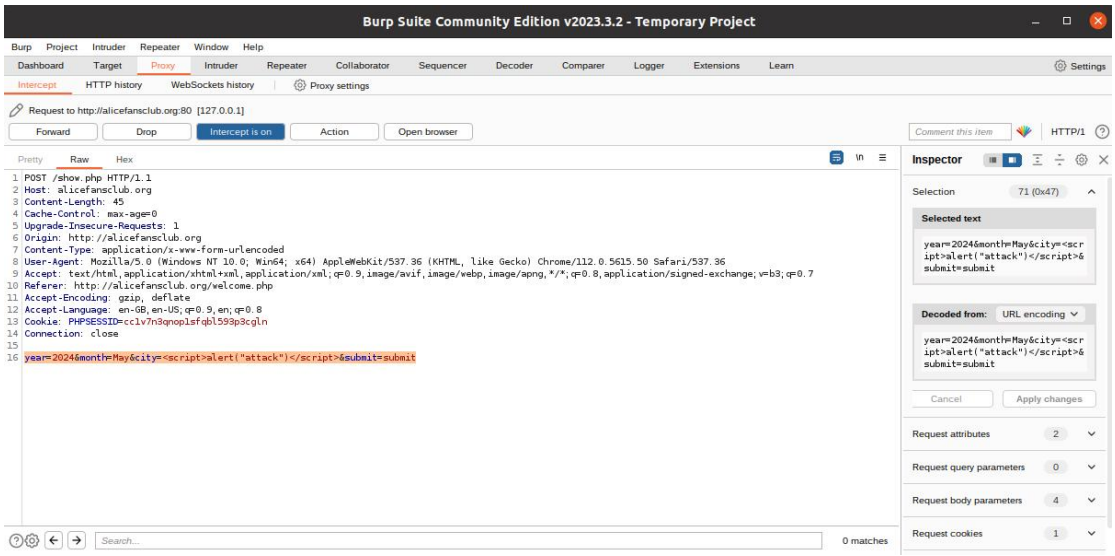
User inputs "Sydney"



Attacker intercepts session and can see what the user has inputted.



The attacker replaces the user's input with their malicious script.



Test

This is the table of results of testing out what happens when the script is put into the input boxes. These are tested both from the user side (directly on website) and the attacker side (intercepted user's session).

Input Field	Test	Vulnerability	Reason
Login Name	<script>alert("attack")</script>	No	The input boxes are sufficiently sanitized
Password		No	
City		No	
Year		No	
Month		Yes	Potential user error occurred (forgot to sanitize)
Event City		Yes	

There are a few ways to mitigate these vulnerabilities:

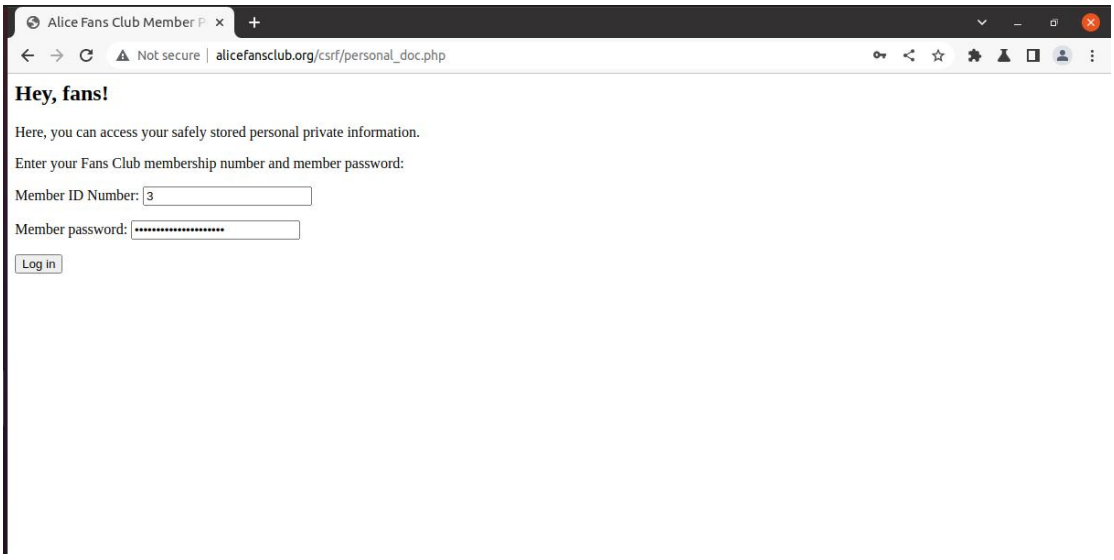
1. Input validation – only accept expected input formats
2. Output encoding – encode user inputs before rendering them

Task 2: Personal Information Security Test

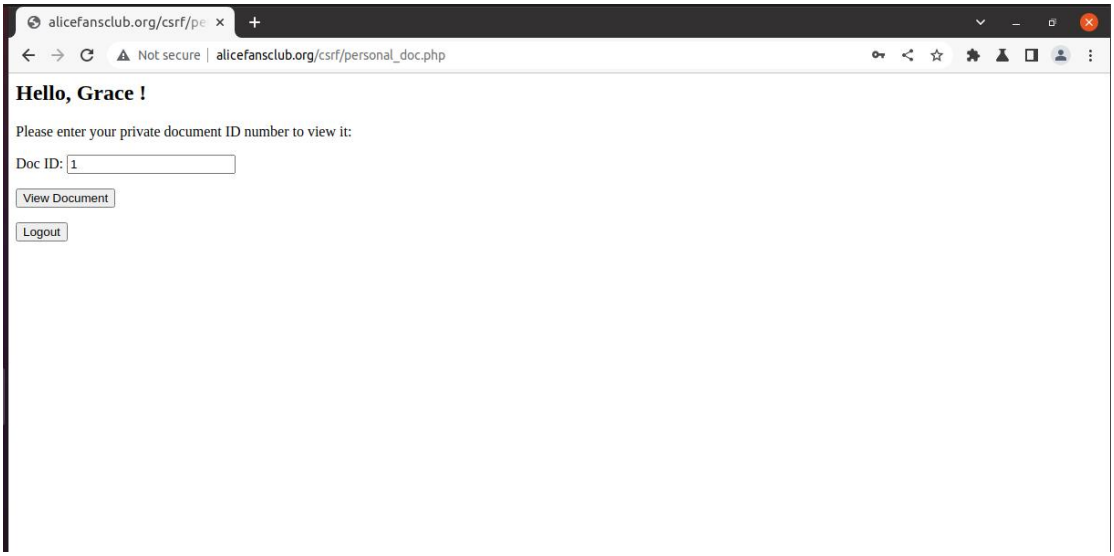
Task 2

Using Grace's account (ID 3), the personal private information part of the web app can be tested.

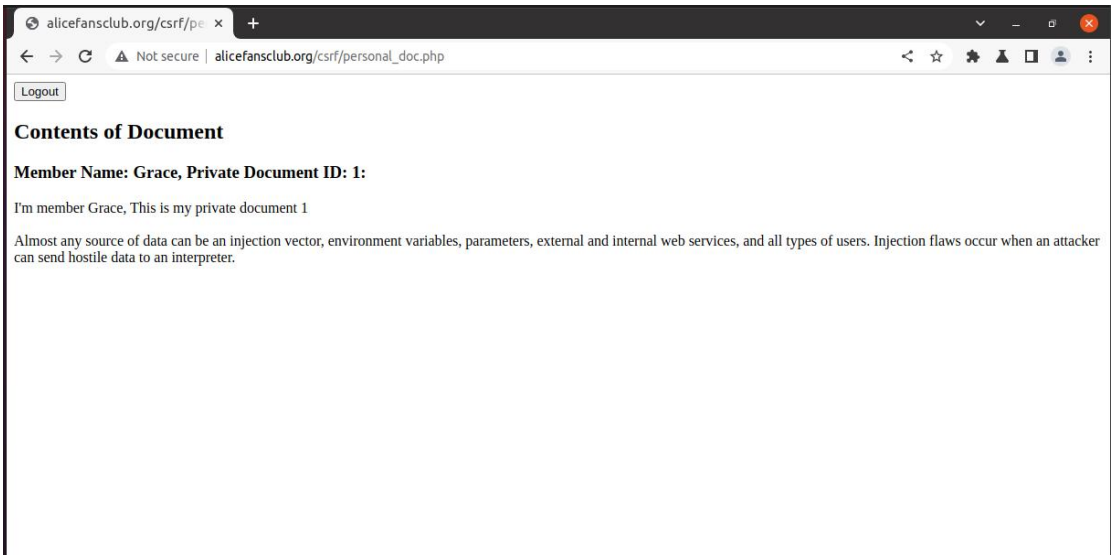
First, login using Grace's ID and password.



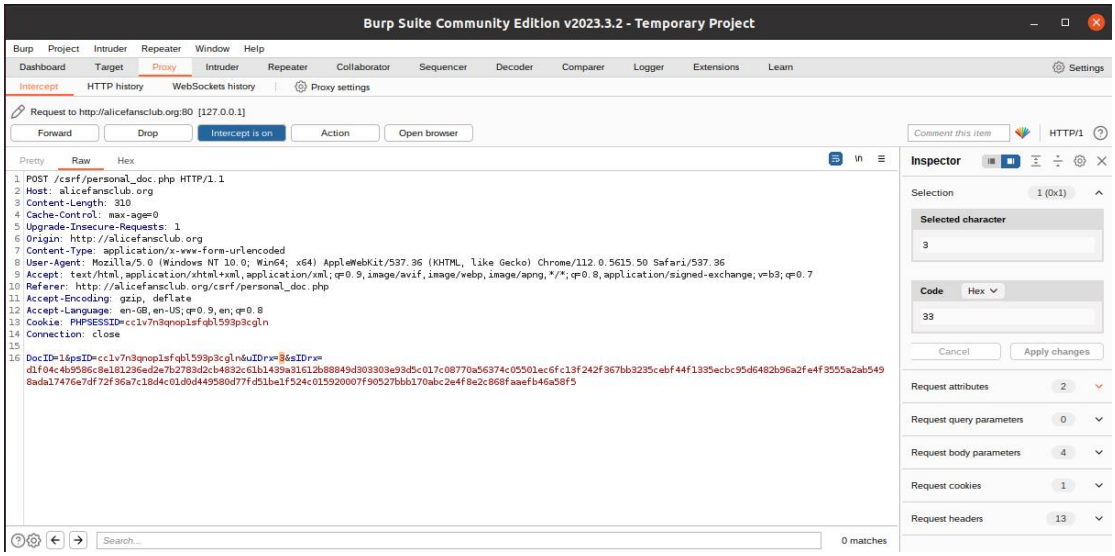
Grace has 2 Doc IDs, 1 and 2. This is what happens when she inputs ID 1.

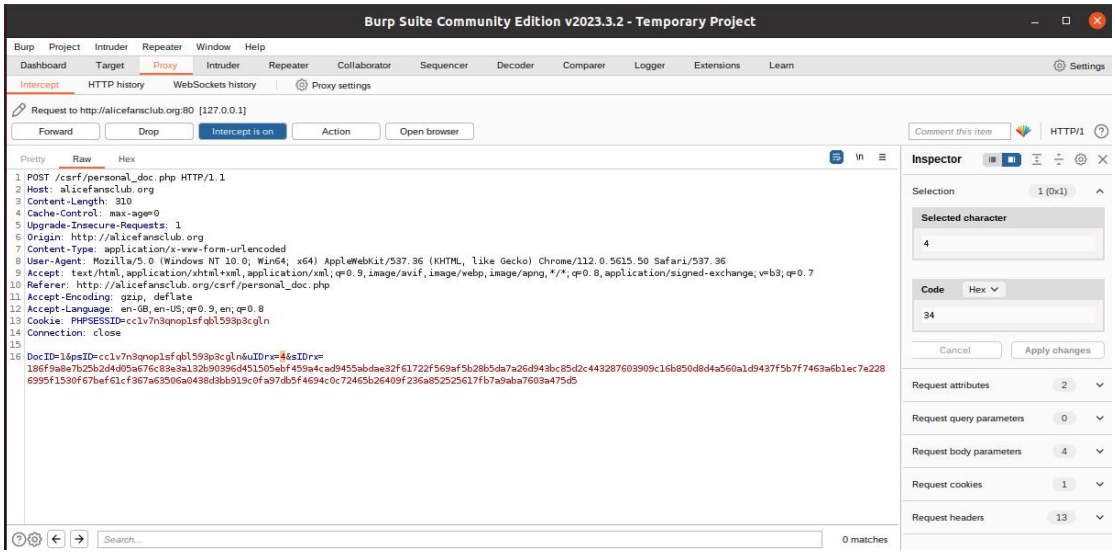


Contents of Doc ID 1.

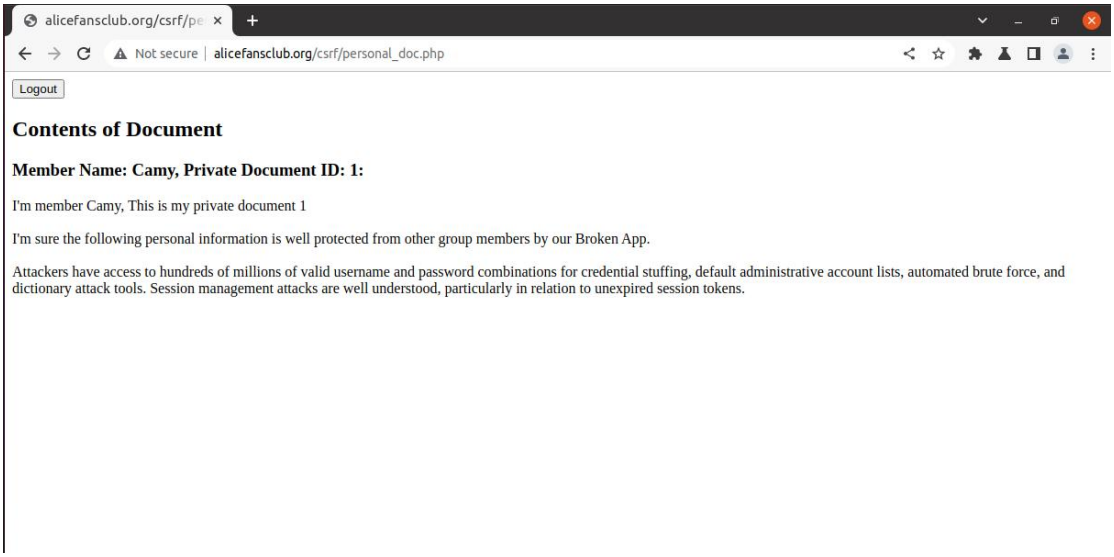


If Grace wated to view another member’s private document. She could perform a CSRF attack by switching her ID (3) to another member’s ID (Camy: ID 4).





This results in Camy’s private document being displayed to Grace.



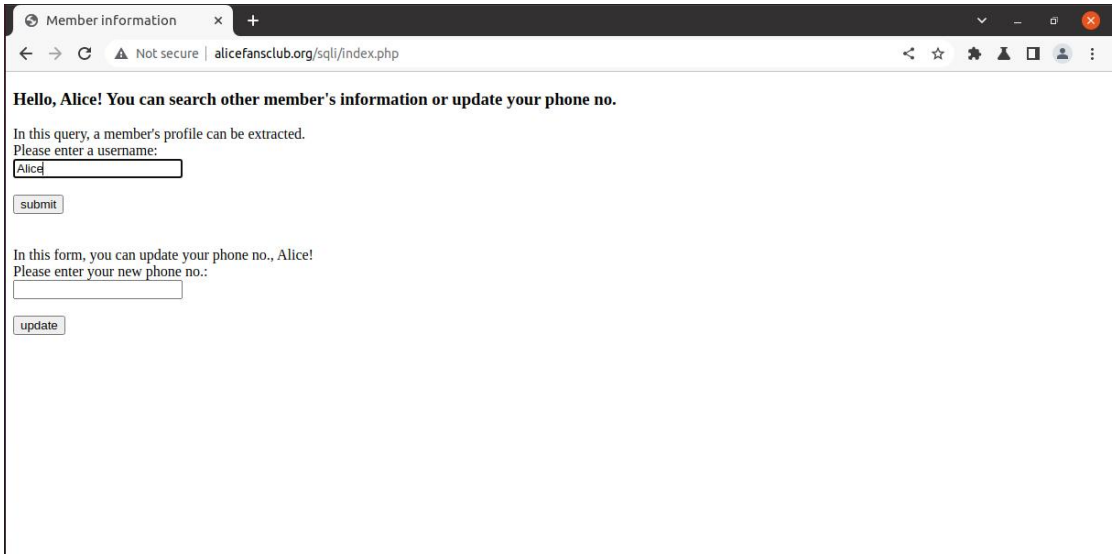
This attack exploits the vulnerability in the web app. As the authenticator only checks the user at the login page and not after a successful login, once Grace logged in to her account, she can simply view another member’s private document by changing the ID via a CSRF attack.

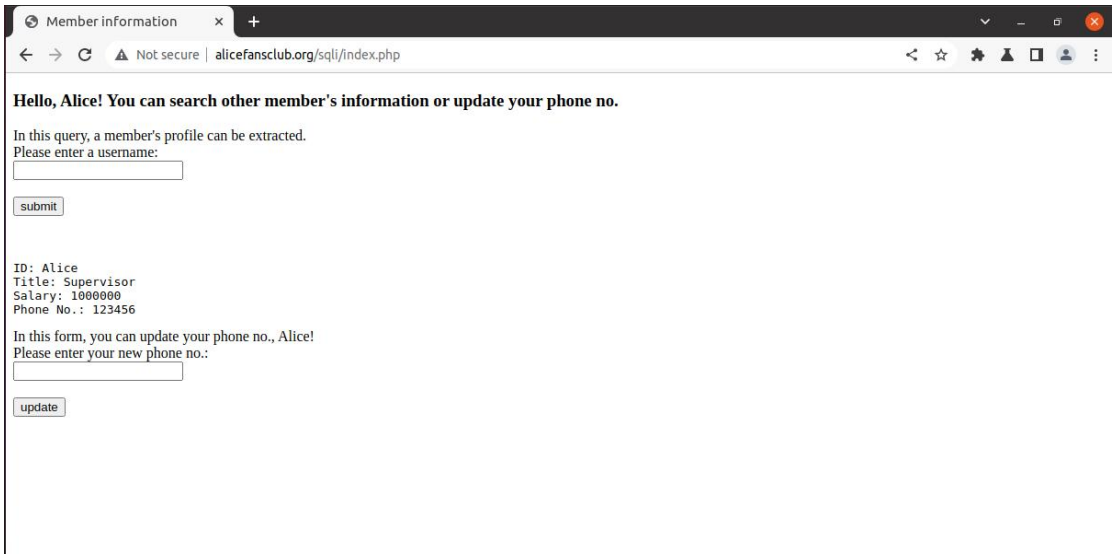
Task 3: Attack on the Database

Task 3A

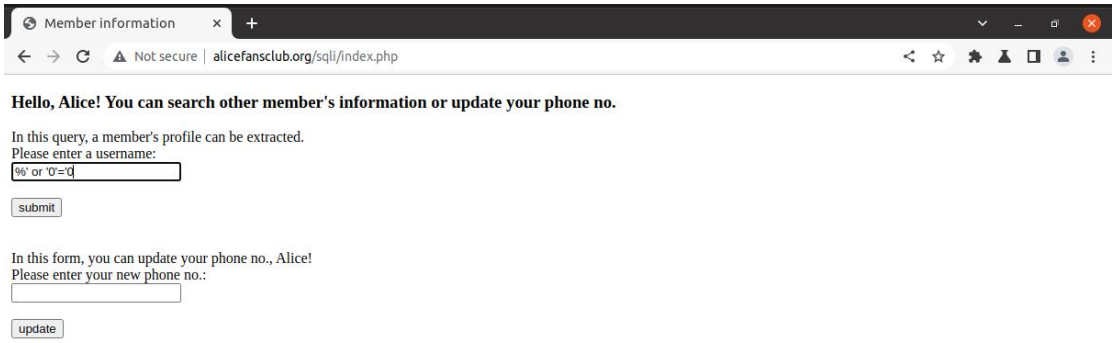
Using Alice's account, the committee's personal profile page can be tested for potential SQL injection vulnerabilities.

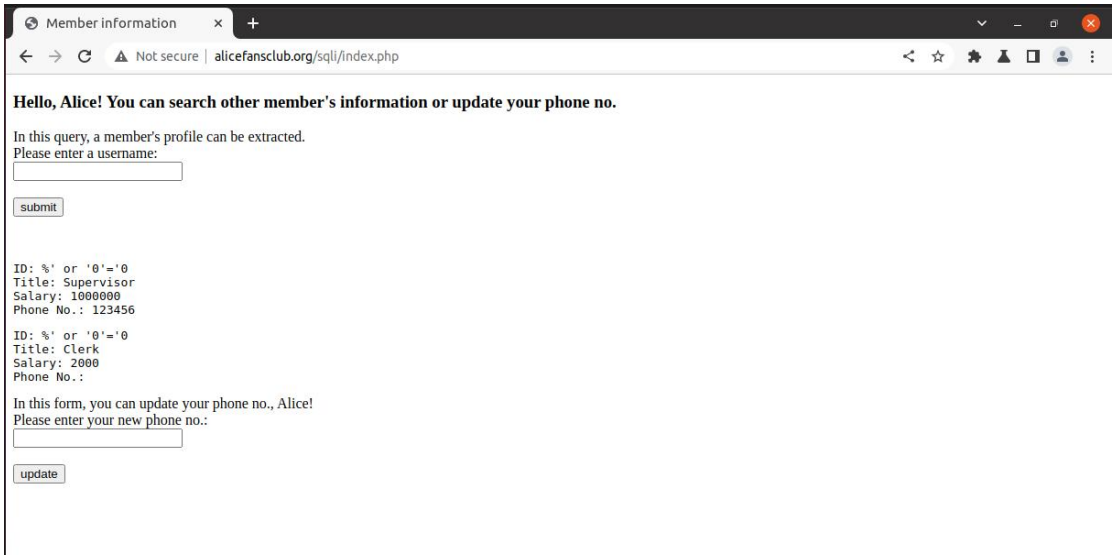
This is what happens when Alice checks her own details.





However, using the command below, Alice is able to obtain the details of every member.





The reason this occurs is because % will be compared as the user ID. It would be unlikely for the IDs to match as the IDs are the member's names. The single quote will end the ID condition and the additional condition added is always true. This results in the list of every member's details in the database being displayed. This is a result of the vulnerability of the input box processing SELECT statements.